GOVERNED AGENT FABRIC

An integrated governance reference architecture for regulated agentic workflows

From workflow assessment to enforceable authority, linked risk records and operational evidence.

Design scope	Evidence delivered
UK banking-inspired synthetic credit workflow	42 Python integration/control tests; 6 Rego tests; 3 Microsoft AGT wrapper checks
Open-source product reference stack	19 article-section mappings; 18 capability/product assignments; 12 open example risks
Research prototype, version 1.0	Source code, reproducible test runner, machine-readable assessment and diagrams

Abstract

A workflow assessment becomes operational governance only when it changes what systems permit, records who holds authority, and remains connected to evidence of outcomes. This paper presents a compositional architecture that links enterprise records to runtime action enforcement. Microsoft Agent Governance Toolkit is evaluated as an optional interception layer, OPA as a business-policy decision service, and CISO Assistant Community Edition as the designated risk system of record.

The implemented laboratory exercises a narrow synthetic credit action, using server-owned facts, signed lab identities, exact-action approvals, serialized limits and transactional evidence. All 51 reported checks pass in the observed run. The results demonstrate specific local control behavior; they do not establish credit-model validity, fairness, distributed resilience, framework conformity or production readiness.

Prepared 2 November 2026 | Technical working paper | Not peer reviewed

No real customer data, banking systems or production credit decisions were used. Named organizational owners, regulatory applicability decisions and product deployment approvals remain unassigned.

Paper navigation

Section	Page
Research question and evidence boundary	3
What the article leaves to implement	4
Architecture and trust boundaries	5
Execution flow and invariants	6
Identity, delegation and exclusive execution	7
Microsoft AGT: adoption and integration	8
Risk register and accountable acceptance	9
Worked approval-substitution risk	10
Data, model and business-system authority	11
Workflow, approvals and distributed effects	12
Evidence graph, retention and integrity	13
Telemetry, incidents and resilience	14
All input and output steps mapped	15-17
Framework alignment and regulatory scope	18
OWASP threats and evidence gaps	19
Experimental method and reproduction	20
Observed results and interpretation	21
Deployment roadmap	22
Limitations and conclusion	23
Primary references	24-26
Component role catalogue	27-29
Expanded native implementation and acceptance	30-33

Companion repository: machine-readable product and step matrices, risk register, framework crosswalk, integration contracts, source code, policy, tests and observed evidence. Diagram sources are supplied as SVG and Mermaid.

Research question and evidence boundary

Question

How can governance of an agentic workflow remain enforceable when the workflow depends on identity, data, models, people, tools and enterprise systems owned by different teams?

Contribution

The contribution is a reference integration design and a reproducible control laboratory. It is not a claim to invent policy engines, durable workflows, zero-trust identity or risk registers. The design makes their boundaries explicit and requires a trace from obligation to risk, control, decision and business outcome.

Evidence level	Meaning in this paper
Specified	A responsibility, interface or operating rule has been designed.
Configured	A configuration or schema is supplied; a configuration file alone is not proof it works.
Tested locally	Code ran with a synthetic system and expected results were checked.
Integrated with selected product	A native product interface was exercised, with a version and result recorded.
Observed in production	Requires real deployment and operational evidence. No component has this status here.

Observed scope

OPA 1.0.1 was run as a real local HTTP service. The Python gateway, signed-token checks, local approval and credit-ledger transactions, and an HTTP outbox sink were exercised. Microsoft agent-governance-toolkit-core 5.0.0 was installed into an isolated target directory and its govern wrapper was exercised in three cases. The wider product catalogue is a target architecture, not a running 18-product deployment.

What cannot be concluded

No generative model was run for these results. No task success, token saving, latency improvement, incident reduction or credit accuracy benefit was measured. A Qwen/Ollama proposal client is provided as an optional extension. Self-authored tests require independent challenge before they support a release decision.

What the article leaves to implement

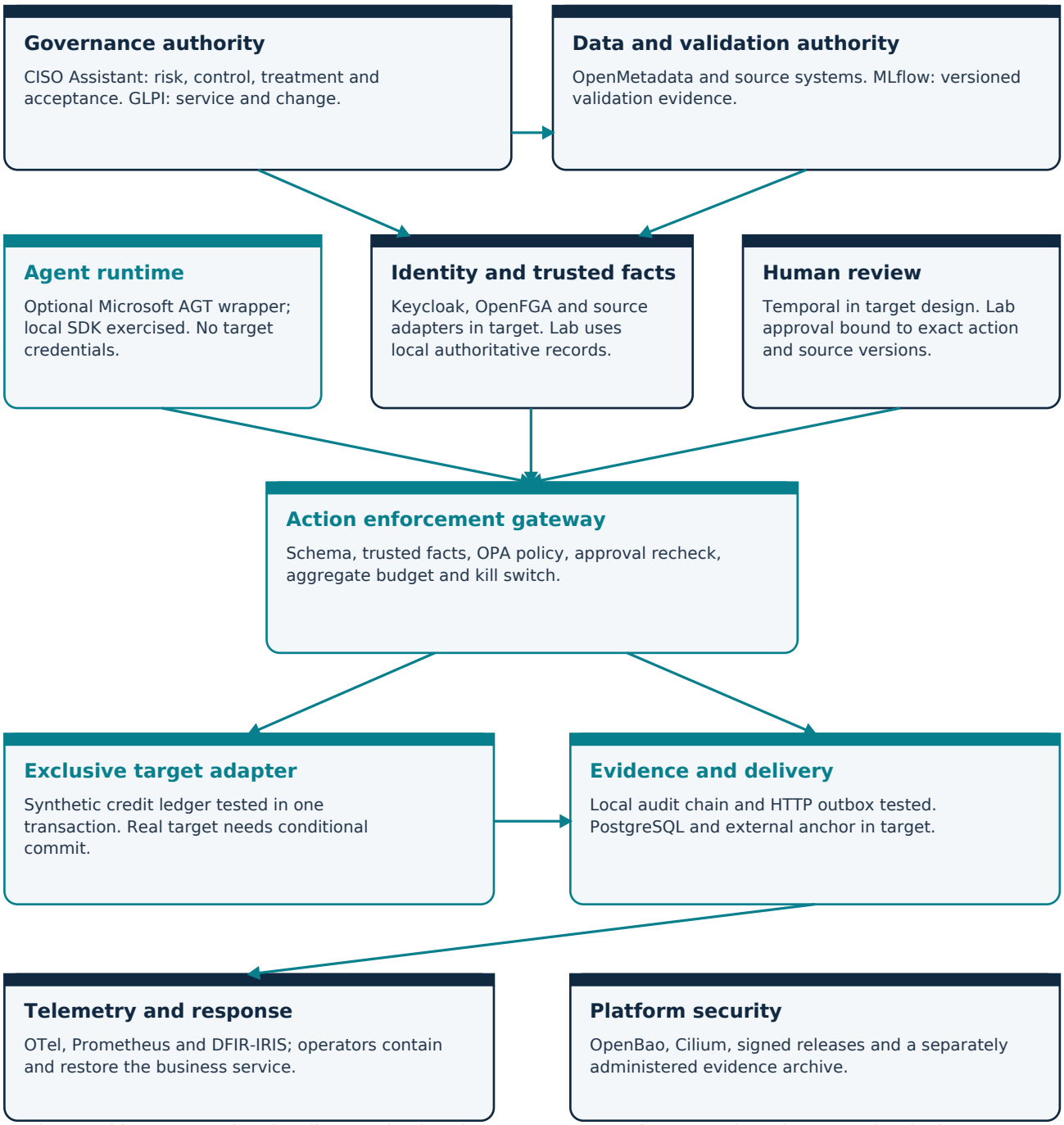
The Erdos Effect article, published 1 November 2026, defines workflow assessment inputs and outputs. It already recognizes operational evidence, control enforcement and accountable decisions. It should therefore be criticized as an incomplete implementation specification, rather than as ignoring governance altogether. [1]

Implementation gap	Our architectural response
Narrative facts may differ from deployed reality	Fetch facts from designated systems of record; retain timestamps, versions and missing-data status.
An assessment does not stop a tool call	Put mandatory enforcement at the tool gateway and target adapter; remove direct agent write credentials.
Human review may authorize the wrong action	Bind approval to actor, exact payload, source version, workflow version, policy version and expiry.
Separate systems disagree or fail	Define precedence, freshness bounds, fail-closed behavior, target receipts and reconciliation.
Risks can become disconnected documents	Maintain one risk identity in the risk register, with control, test, event and incident references.
One approved workflow can create shared exposure	Enforce aggregate budgets and cross-workflow limits at a shared authoritative service.
Operational telemetry can be mistaken for assurance	Require independent validation, business outcomes, customer impact and time-limited acceptance.
Controls may be technically bypassable	Isolate workload networks and secrets; test alternate write paths and unauthorized delegation.

Fair comparison

No executable reference implementation accompanies the supplied article link. Consequently this paper does not compare execution performance against the article or present a fabricated baseline. It translates the assessment specification into architecture and tests a defined subset of the resulting controls.

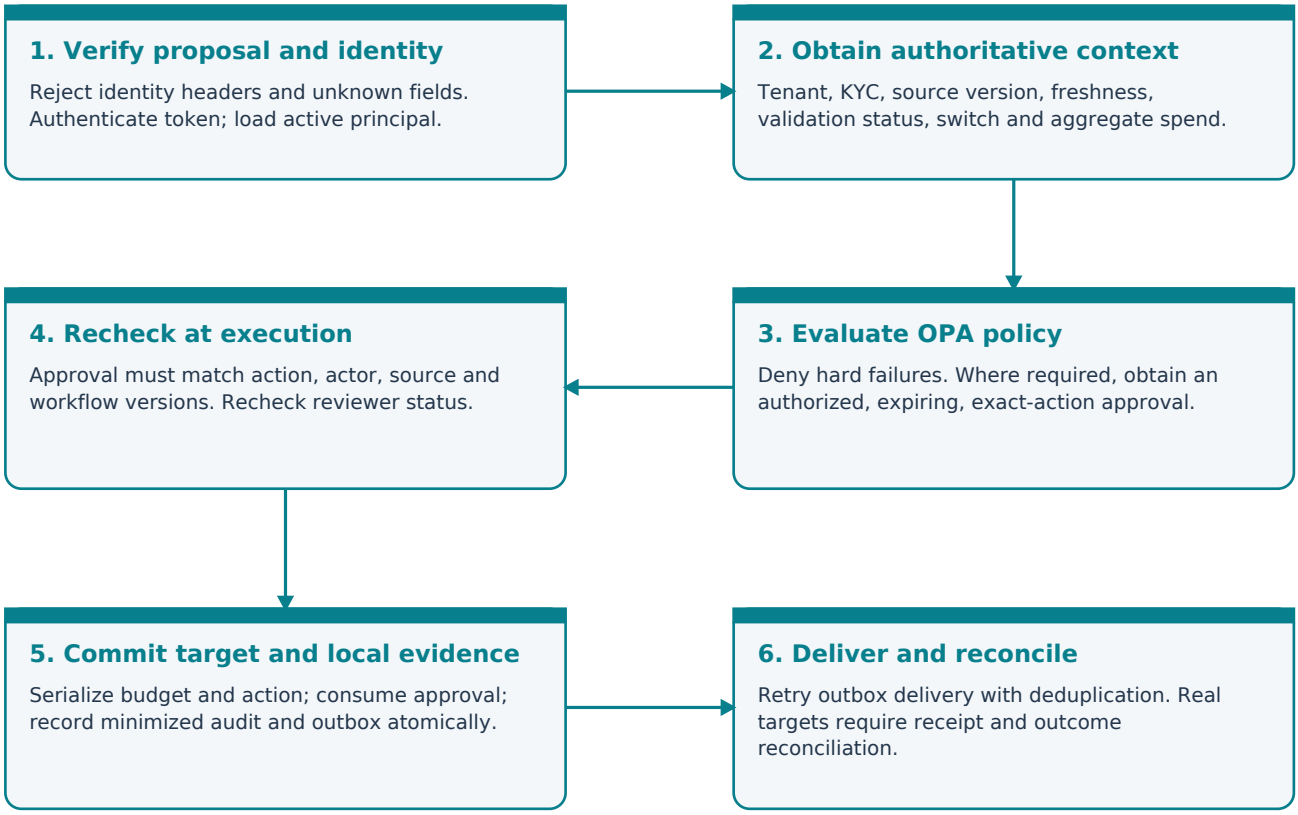
Architecture: responsibilities and trust boundaries



Teal-topped boxes contain a locally exercised path or component. Other named products require deployment and native integration. A tested local substitute does not imply that the named enterprise product has been connected.

The governance authority owns policy and risk decisions. The execution authority enforces them. The evidence plane records decisions and outcomes. Data and validation authorities supply trusted facts; model-generated content cannot amend those facts.

Execution flow and decision invariants



Lab guarantee: one SQLite transaction. Production guarantee: target-enforced idempotency, expected-version commit, receipts and reconciliation; no global exactly-once claim.

Commit invariant

A new write is permitted only when identity is active; principal and case share a tenant; the tool is allowlisted; required facts are fresh and valid; workflow validation remains current; the switch permits execution; both single-action and aggregate limits hold; and any required approval remains valid.

Important retry distinction

A duplicate request with the same actor, tenant, idempotency key and payload returns its prior receipt without creating a new write. It may return an existing receipt after a stop or source expiry. A changed payload with the same key is rejected. This is intentional retrieval of an earlier outcome, not renewed authorization.

Identity, delegation and exclusive execution

Keycloak: authenticate the actor

The target uses Keycloak for human and service identities through OpenID Connect. The gateway must validate issuer, intended audience, signature, token lifetime and authorized client, using a trusted discovery/JWKS configuration. Tenant, role and task scope must originate from trusted identity and authorization services. A tool-call body cannot nominate its own privileges. [8]

OpenFGA: authorize relationships

Record-level relationships answer whether the user may operate the case and whether this agent is assigned. Authorization is the intersection of the delegating user, workload identity, current task and target record. A relationship grant does not waive OPA business restrictions. The supplied FGA model is illustrative and has not been deployed. [9]

Microsoft AGT: intercept agent proposals

AGT is used at the agent runtime boundary to reject unrecognized tools before they reach a gateway. Its independently configured policy cannot turn a central deny into an allow. Dynamic trust scores, if adopted, may restrict authority or trigger review; they must not create a legal delegation or silently expand a business limit.

OpenBao and platform isolation: protect the only write route

OpenBao is the proposed source of short-lived adapter credentials and certificate/key operations. Kubernetes and Cilium should restrict agent egress to the authenticated gateway, with target credentials available only to the adapter. Database accounts and administrative roles must not share the agent runtime. [10]

Implemented boundary and remaining work

The lab verifies a narrow RS256 token profile using cryptography and checks a server-owned active-principal table. Its keys are generated locally, with the private key excluded from the repository. It is not a Keycloak/JWKS client and does not provide rotation, federated logout, mTLS or a complete token-replay defense. It listens on loopback only. An authenticated production gateway and network bypass test remain release blockers.

Microsoft AGT: adopt, integrate and constrain

AGT is a Microsoft-hosted, MIT-licensed runtime governance project in Public Preview. Current documentation describes policy, identity, isolation and reliability capabilities and support for external policy engines. Our architectural evaluation treats those as useful components, rather than assuming that every capability is enabled or equally mature across packages and languages. [7]

Responsibility	AGT fit	Required enterprise connection
Tool interception	Useful wrapper and framework integration surface	Mandatory remote gateway with independent target enforcement
Policy	Can host/integrate governance policy	One centrally managed OPA business-policy authority; versioned contract
Identity and trust	Agent identity/trust capabilities are available	Map to enterprise IAM, real delegation, customer/record permissions
Isolation and termination	Runtime/sandbox and stop capabilities are available	Credential revocation, network restriction and service recovery
Evidence	Runtime governance evidence is available	Correlate with approvals, target receipts, GRC and incident records
Risk management	Evidence and mappings can inform risk processes	CISO Assistant remains our designated risk acceptance record

What was actually exercised

The core 5.0.0 govern wrapper permitted credit.commit to reach OPA; rejected an unknown shell.exec action; and allowed a proposal that OPA independently rejected for crossing tenants. All three assertions passed. These tests do not exercise AGT sandboxing, inter-agent trust, framework adapters, distributed audit or SRE behavior.

Avoid policy ambiguity

AGT local deny and central OPA deny both stop execution. Local allow means only that the proposal may be submitted for business authorization. No fallback from an unavailable central policy service to local allow is permitted. The lab deliberately uses this simple composition instead of maintaining two competing versions of the credit policy.

Microsoft Agent Control Specification and the OWASP Agent Control Standard both use the acronym ACS; they must be tracked as distinct artifacts. Upstream main documentation can evolve beyond a released package, so the implemented adapter is validated against the installed 5.0.0 wheel, not inferred solely from README examples.

Risk register and accountable acceptance

CISO Assistant Community: system of record

CISO Assistant Community Edition is selected to hold the risk, control, assessment and treatment records. Its repository distinguishes an AGPLv3 Community Edition from commercial editions. Selected-release licensing and API access must be checked before deployment. The supplied JSON/CSV register is portable seed data, not evidence of a native CISO Assistant integration. [11]

Risk identity and relationships

Each risk has an external stable ID, workflow version, failure scenario, impacted assets or people, owner, inherent and residual assessment, rating rationale, uncertainty, controls, evidence references, treatment status, acceptance authority and expiry. Incidents link to the same risk ID. Multiple agent observations should not create unrelated duplicate risks.

Who may change what

Actor	Permitted contribution	Reserved authority
Governance agent	Propose scenario, attach evidence, flag changed assumptions	Cannot accept risk or certify a control
Control owner	Implement control and submit verification evidence	Cannot independently validate their own critical model
Risk owner	Approve rating, treatment, residual exposure and review	Must operate within delegated risk appetite
Independent validation	Challenge method, evidence and model limitations	Does not take ownership of the business decision
Release authority	Approve permitted scope and conditions	Cannot disregard hard legal or prohibited-action constraints
SOC/SRE	Contain incidents and request suspension	Cannot silently close accepted risk or reset audit history

No invented ratings

Twelve synthetic risk entries are populated. Inherent and residual ratings remain Not assessed because organization-specific exposure and likelihood evidence is absent. Named owners, acceptance authority and review dates remain null. All treatments are open. Passing a technical test is recorded as evidence, not as automatic acceptance.

Worked risk: action changes after approval

R02: approval substitution

An agent prepares a synthetic commitment of GBP 2,000 for case-a. An authorized independent reviewer approves that exact request. The agent then attempts GBP 3,000 or uses a case whose source version changed. A generic workflow-level approval would be inadequate to distinguish those actions.

Risk field	Populated reference value
Cause and failure	Approval refers to an earlier interpretation rather than the exact committed action.
Potential consequence	Unauthorized exposure, incorrect record change, disputed customer outcome and investigation cost.
Preventive control	Hash the canonical payload plus actor, case version, workflow version and policy version. Approval is single-use and expires after 300 seconds.
Execution check	Check reviewer remains active and authorized, compare the bound hash, then re-evaluate current policy under the transaction lock.
Observed evidence	Amount substitution, case version change, workflow version change, expiry and reviewer revocation all deny in local tests.
Residual uncertainty	Production target consistency, reviewer deception, signing-key compromise and remote-service race conditions are not resolved by this test.
Accountability	Credit operations risk owner must be named. Independent review is required before any acceptance.

Integration event example

A denied attempt emits a minimized evidence event and a separate incident event in the local transaction. The outbox retains an undelivered event during a remote outage. A production bridge should deduplicate by event ID, attach the target receipt, update R02 evidence and open or correlate an IRIS incident. It must not overwrite an owner-approved rating.

Closure is a review decision

A completed remediation ticket is not sufficient for closure. The control must be retested against the relevant release, residual uncertainty recorded, and an authorized owner must decide whether to accept the remaining exposure or further restrict autonomy.

Data, model and business-system authority

OpenMetadata: facts about the data

The metadata layer identifies assets, owners, classifications, quality results and lineage. These records help determine whether an input is usable for a defined purpose, but they do not themselves grant data access. The source adapter enforces record and field scope before data is returned to the agent. [12]

KYC and core credit: facts about the customer and commitment

The gateway must obtain KYC status, case tenant, source version and observation time from an authoritative source. The lab uses synthetic database rows. It does not implement identity verification, sanctions screening, AML investigation, affordability, credit scoring or underwriting policy. A clear KYC fixture is only one test input, not evidence that those obligations are met.

MLflow: facts about the evaluated artifact

MLflow provides the proposed model/prompt registry and evaluation artifact store. The release record should identify model and prompt digests, data versions, intended use, limitations, evaluation results, independent validator, approval and expiry. Runtime use is blocked when the approved version or validation window no longer matches. The lab demonstrates a synthetic validation-expiry gate; no MLflow server was deployed. [13]

GLPI: facts about the business service

Service identity, owner, important dependencies, criticality and change records belong in the established inventory/change process. GLPI is the open-source reference choice. An enterprise may retain its existing CMDB/ITSM system and use an adapter. A second disconnected governance inventory is undesirable when a reliable authoritative record already exists.

Conflicts and unknowns

A missing authoritative record is unknown, not a positive compliance assertion. Conflicting facts require an explicit source-precedence rule and review. Current legal applicability comes from a qualified interpretation and dated source, not model confidence. Source owners define freshness and validity; the artificial 60-second lab bound is not proposed as a universal enterprise setting.

Workflow, approvals and distributed effects

Temporal: durable control flow

Temporal is the proposed owner of long-running state, human waits, timers, bounded retries and recovery orchestration. Signals must come through an authenticated bridge; a workflow signal is not automatically an authorized business approval. Store an approval reference in history, keeping access tokens and unnecessary personal data out. [14]

Target adapter: the execution authority

The adapter accepts only typed, allowlisted operations. It maps a canonical action to the target API, checks expected record version and propagates a scoped idempotency key. Arbitrary SQL, shell execution, arbitrary URLs and arbitrary recipients are outside this credit adapter. Delegation cannot expand the tool or data scope.

No fictional distributed transaction

The lab commits action, approval consumption, audit and outbox in one SQLite transaction. A real core system cannot generally participate in that same transaction. The production adapter therefore needs target-supported idempotency, conditional updates and receipts, plus an intent/outcome journal and reconciliation when the response is lost. Retries must not blindly repeat an irreversible business operation.

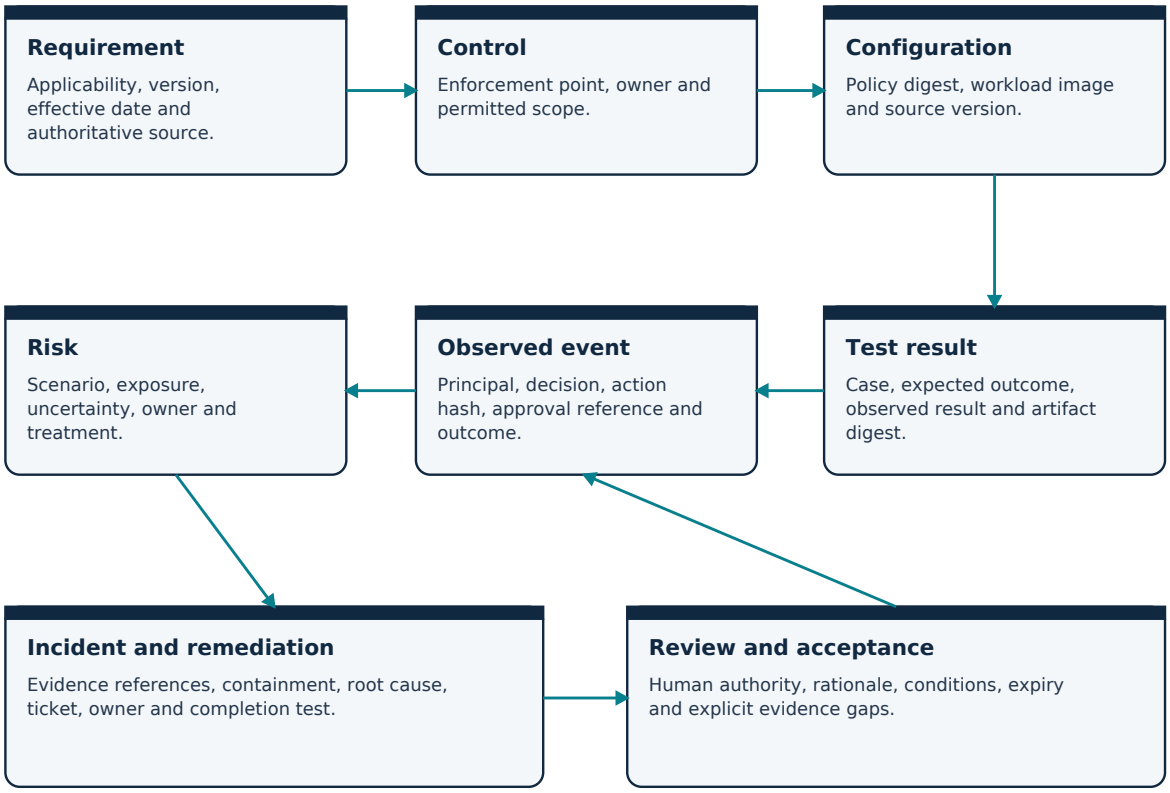
Compensation and irreversibility

A compensating action is a new authorized business operation, not a guaranteed undo. A released payment or an external message may be irreversible. Classify each target operation, define safe cancellation points, identify permitted compensation, and require human recovery for uncertain outcomes. A saga diagram is insufficient without those business rules.

Budget semantics

The lab enforces a lifetime tenant budget of GBP 15,000, a per-action ceiling of GBP 10,000, and human review above GBP 1,000. Amounts are integer pence. Budget and action writes serialize, preventing concurrent requests from overspending this local ledger. Production needs defined time windows, multi-currency conversion, reservations, cancellations, cross-workflow aggregation and target reconciliation; none are silently assumed here.

Evidence graph, retention and integrity



Why a graph matters

The useful property is the explicit relationship among artifacts. A risk record should lead to its controls, test cases, deployment configuration, observed decisions and incidents. A policy or model change should reveal which approvals and assessments need review. PostgreSQL can store these edges without requiring a separate graph database.

Integrity boundary

The lab SHA-256 chain detects edits to a stored event body if the chain is left unchanged. It does not resist a privileged operator who rewrites the complete chain or truncates its tail. Production needs signed checkpoints anchored to a separately administered store, restricted archival roles, retention/legal-hold controls and verification against the external checkpoint. Hashing is not anonymization or WORM storage.

Delivery and consistency

Outbox delivery is at least once. Receivers must deduplicate event IDs, acknowledge accepted updates and expose failures for reconciliation. A risk-register outage does not erase queued evidence. Production must also define backlog limits and a policy for whether a prolonged evidence-export outage restricts new writes.

Telemetry, incidents and service resilience

OpenTelemetry and Prometheus

The observability plane should expose policy decision outcomes, dependency health, source age, validation expiry, approval latency, adapter errors, execution receipts and outbox backlog. Correlate by workflow run and evidence references rather than logging complete prompts or customer records. OpenTelemetry documents sensitive-data handling; the provided collector configuration is an unexecuted reference, not comprehensive DLP. [15]

DFIR-IRIS instead of current TheHive

DFIR-IRIS 2.x is the open-source incident-management reference. Its deployment and API bridge need to be qualified against a selected stable release. Current TheHive is commercially distributed, so it is not used as the core open-source choice. A free community license must not be confused with current open-source licensing. [16,17]

Containment must reach the business write path

On a serious event, SOC/SRE pauses new affected actions at the gateway, revokes credentials where necessary, preserves evidence, identifies in-flight and uncertain target operations, and invokes a manual service path. Resuming requires reconciled state, remediation evidence and an authorized decision. Stopping an agent process alone does not revoke another worker or credential.

Availability and safety are joint requirements

Fail-closed authorization protects the write boundary but may disrupt an important business service. The firm must define impact tolerances and exercise severe-but-plausible outage scenarios with a controlled manual alternative. The synthetic stop and OPA-outage tests show denial, not that a banking service recovers within tolerance. Applicable FCA/PRA operational resilience obligations are assessed at firm and service level. [6]

Illustrative acceptance measures, not observed results

Before a pilot, agree policy-error and outbox-backlog alerts, maximum source age, manual fallback capacity, detection and revocation objectives, restoration objectives and escalation owners. These values depend on business harm and operating context. The paper intentionally does not invent a universal latency SLO or assert that the current lab meets one.

Full input coverage: steps 3.1.1-3.1.7

Article ID / capability	Product responsibility	Evidence and gate
3.1.1 / Business mandate	GLPI + CISO Assistant	Service ID, jurisdiction, objective, criticality, baseline benefit. No approved owner or scope: deployment blocked
3.1.2 / Process and dependency model	Temporal + OpenMetadata	Versioned activities, people, systems, decisions, failure paths. Unmapped side-effecting step: deployment blocked
3.1.3 / Delegated authority	Keycloak + OpenFGA + AGT + OPA	Principal, delegation chain, exact tools, scopes and limits. Unknown authority: deny action
3.1.4 / Trusted information	OpenMetadata + OpenBao	Classification, purpose, region, source version, quality, retention. Missing or stale authoritative fact: deny action
3.1.5 / Accountability and redress	CISO Assistant + GLPI	Decision rights, approver, affected people, appeal route. No authorized accountable role: no release
3.1.6 / Obligation applicability	CISO Assistant + Git + OPA	Dated requirement, jurisdiction, applicability rationale, policy mapping. Unknown applicability goes to qualified review
3.1.7 / Operational assurance	MLflow + OTel + DFIR-IRIS	Config, tests, observed events, incidents and changes. Expired validation: restricted or stopped

The full CSV adds the accountable role for every row. These assignments implement the integration design; product names do not imply a running connector. Every source record must have an owner, authority, version and freshness contract.

Full output coverage: steps 4.1-4.6

Article ID / capability	Products	Operational interpretation
4.1 / Completeness and conflict review	CISO Assistant + OpenMetadata	Coverage and missing or conflicting source records. Unknown remains unknown
4.2 / Readiness decision	CISO Assistant + Temporal	Disposition, conditions, authority and dated approval. Agent advice cannot authorize release
4.3 / Control analysis by activity	CISO Assistant + OPA	Activity, failure scenario, enforcement point, control and test link. No effective enforcement: unresolved gap
4.4 / Risk record	CISO Assistant Community	Cause, impact, rationale, uncertainty, controls, residual risk, treatment. Only owner can accept; never auto-close
4.5 / Autonomy boundary review	Keycloak + OpenFGA + AGT + OPA	Needed versus actual permissions, task limits, delegation ceiling. No increase from parent authority or trust score
4.6 / Control implementation	OPA + AGT + OpenBao + Cilium	Enforcement code, configured product, negative test, evidence. Advisory rules are not execution controls

scripts/assess.py generates structured output sections from test results, open risks and implementation status. It explicitly limits readiness to laboratory use and preserves missing evidence. It is a deterministic evidence pack generator, not an autonomous legal or compliance assessor.

Full output coverage: steps 4.7-4.12

Article ID / capability	Products	Operational interpretation
4.7 / Traceable assurance	CISO Assistant + PostgreSQL + OpenMetadata	Requirement-control-configuration-test-event-risk links. Traceability is not compliance certification
4.8 / Validation and evaluation	MLflow + Fairlearn + unittest + OPA tests	Business correctness, adversarial cases, fairness, resilience, thresholds. Unvalidated dimensions remain open
4.9 / Operations and incidents	OTel + Prometheus + Alertmanager + DFIR-IRIS	Alerts, containment, manual service fallback, recovery and review. Control-plane outage blocks writes; fallback must be rehearsed
4.10 / Value and proportionality	CISO Assistant + MLflow + Prometheus	Baseline task outcome, control cost, loss exposure, supervision cost. No unmeasured claims of savings
4.11 / Remediation delivery	GLPI + Git + CISO Assistant	Ticket, due date, dependency, acceptance test, completion evidence. Release-blocking issues require verified completion
4.12 / Versioned assessment package	Git + PostgreSQL + CISO Assistant	Signed artifact manifest, source snapshots, control and evaluation versions. Material changes invalidate previous approval

Monitoring does not replace assessment; remediation does not replace validation; an assessment report does not replace a release authorization. Material changes to tools, permissions, sources, policy, model or scope must trigger the appropriate reassessment and invalidate incompatible approvals.

Framework alignment and regulatory scope

NIST AI RMF supplies an organizing risk-management structure. Its GOVERN, MAP, MEASURE and MANAGE functions are used to assign responsibilities and evidence, rather than to declare a binary pass. NIST AI 600-1 adds generative-AI risk considerations; the organization must select relevant actions for its role and use case. [2,3]

Reference	Architecture consequence	Assurance limit
NIST SP 800-53 Rev.5	AC-3/5/6 access and duties; AU-2/9 evidence; CM-3 change; CA-7 monitoring; IR-4 response	Control objectives mapped. A complete tailored baseline and assessment are not supplied.
OWASP Agentic Top 10 2026	Threat categories drive negative tests and production security work	No full coverage or OWASP certification claim.
PRA SS1/23	Model inventory, governance, development/use, independent validation, mitigants	Firm scope and model applicability must be assessed using the current statement.
UK privacy and ADM safeguards	Purpose, lawful processing, human intervention, explanation and contestability	DUAA changed the landscape; older Article 22 summaries cannot be assumed current.
Operational resilience	Business service dependencies, impact tolerance, fallback and restoration	Policy-outage denial alone does not demonstrate service resilience.
ISO/IEC 42001	Management-system responsibilities, review and continual improvement	Only high-level alignment. No access to licensed clauses or certification assessment claimed.
BCBS 239 where applicable	Risk-data authority, quality, completeness, timeliness and lineage	Applicability varies by bank and supervisory scope.

Sources: NIST [2-4], OWASP [5], PRA [18], ICO/legislation [19-21], ISO [22] and BIS [23]. Mappings are architecture judgments, not endorsements or legal opinions. New jurisdictions, retail/commercial scope, outsourcing arrangements and intended uses require their own applicability profiles.

OWASP threats: demonstrated and unresolved

Threat	Current evidence	Remaining gap
ASI01 / goal hijack	Typed actions, trusted context and independent OPA restriction	No model prompt-injection attack benchmark
ASI02 / tool misuse	Tool allowlist, amount limits and aggregate-budget tests	Real adapter and alternate-path attack tests open
ASI03 / identity abuse	Signed lab tokens, active-principal and tenant checks	Keycloak, OpenFGA and real delegation not connected
ASI04 / supply chain	Release design calls for SBOM, scan and signed provenance	No supply-chain pipeline executed
ASI05 / code execution	No shell tool exposed in this synthetic adapter	No sandbox escape or kernel isolation test
ASI06 / poisoned context	Source freshness, version and KYC tests	No RAG/memory poisoning evaluation
ASI07 / inter-agent channel	Enterprise identity/mTLS design specified	No inter-agent communication experiment
ASI08 / cascading failures	OPA outage denial and serialized exposure checks	No multi-service chaos or restoration exercise
ASI09 / human trust	Exact-action approval binding tested	No evidence that reviewers resist deceptive narratives
ASI10 / rogue agents	Local stop and revocation behavior tested	No distributed fleet containment exercise

The categories are used as a threat catalogue [5]. The row-level assessment above belongs to this paper. Product-level coverage claims are not substituted for evidence of the configured deployment.

Method and reproducible experimental setup

System under test

The laboratory comprises a Python gateway and local state store, a separate OPA HTTP process, generated RSA lab keys, a synthetic case/identity/validation inventory and a synthetic credit commitment ledger. An HTTP receiver verifies outbox behavior. Optional Microsoft AGT wraps the same gateway entry point. All tests run without real customer data or external bank credentials.

Test design

Checks are organized around security boundaries and invariants: valid execution; tenant and role isolation; unknown tool and field rejection; KYC/region/freshness conditions; validation expiry; approval eligibility, substitution, expiry and revocation; action/aggregate limits; concurrent calls; retry conflict; policy dependency outage; audit transaction rollback; local tamper detection; HTTP authentication; delivery outage and persistent state across restart.

Run commands

```
python3 -m venv .venv
source .venv/bin/activate
python3 -m pip install -r requirements.txt
OPA_BIN=/absolute/path/to/opa python3 scripts/test_all.py
python3 scripts/assess.py
```

For the optional AGT checks, install agent-governance-toolkit-core==5.0.0 in a separate virtual environment, then run scripts/test_agt.py with the OPA_BIN environment variable. In the observed environment the SDK was installed to a temporary target directory and selected using PYTHONPATH. Review and pin the resolved dependencies before regulated deployment.

Version discipline

The observed control run used Python 3.12.14, cryptography 50.0.2 and OPA 1.0.1. The optional AGT dependency set resolved cryptography 49.0.0 separately. OPA 1.0.1 is a historical reproduction target, not a claim that it is the current secure production release. The source artifact digest and test metadata are recorded; upstream binary provenance and a current vulnerability assessment remain release requirements.

Observed results and interpretation

Check group	Observed result	What it establishes
Python control and HTTP checks	42 run; 0 failures; 0 errors; 0 skipped	Specified local boundaries produced expected outcomes in this run.
OPA Rego policy checks	6 passed	Selected policy decisions behaved as expected under controlled inputs.
Microsoft AGT wrapper checks	3 assertions passed	Wrapper allow/deny works for the exercised cases; central OPA deny remains effective.
Concurrent shared exposure	20 requests of GBP 1,000; 15 committed, 5 denied	Serialized local lifetime tenant budget did not exceed GBP 15,000.
Audit write failure	Synthetic insert failure rolled back action	No local action committed without its transactionally required evidence.
Outbox receiver outage	Event remained undelivered for retry	Local delivery state survives a failed attempt; no native GRC/IRIS claim.

Research interpretation

The observations support the engineering proposition that a narrow action gateway can enforce deterministic controls independently of an agent narrative. They do not show superiority to Microsoft AGT, the article, a commercial GRC platform or an enterprise control environment. No comparative cost, performance or business outcome experiment was conducted.

No statistical assurance from a perfect test run

The checks are designed examples, not a randomly sampled deployment population. A 51-of-51 result must not be interpreted as a quantified incident probability, general safety rate or complete adversarial coverage. The test author also implemented the controls, so correlated omissions remain possible.

Evidence files

results/summary.json and tests.log record the control run; rego-tests.log records policy checks; agt.json and agt-test.log record the optional SDK experiment; assessment.json preserves the twelve structured assessment outputs. The raw source and assertions permit independent reruns and extensions.

Product deployment and acceptance roadmap

Stage	Concrete implementation work	Exit evidence
1. Qualify the environment	Name owners; determine legal/firm scope; choose supported releases and approved licensing; define business service and risk appetite	Signed scope, obligation profile, dependency/license register
2. Connect authority	Deploy IAM and relationship checks; implement real KYC/core, metadata, validation and CMDB adapters; define freshness and precedence	Connector tests, access evidence, version-conflict and revocation tests
3. Enforce exclusive writes	Deploy gateway/adapter isolation, OpenBao credentials and target idempotency; implement conditional commits and reconciliation	Bypass tests, replay tests, lost-response tests and target receipts
4. Connect GRC and incidents	Implement CISO Assistant and IRIS API bridges with durable external IDs, optimistic concurrency and deduplication	Native-product round-trip tests and human-approved risk updates
5. Validate outcomes	Add representative credit decisions, fairness, explanations, redress and human-factor tests; independent validation	Approved validation report and unresolved limitations
6. Exercise operations	Add metrics, thresholds, bounded queues, manual fallback, restoration, external evidence anchors and incident drills	Measured impact-tolerance and restoration evidence
7. Controlled pilot	Restrict cases, tools and exposure; use time-limited authorization; monitor harm and business value	Release approval, pilot outcome review and explicit expansion decision

Small deployment first

Adopt existing enterprise systems of record wherever possible. Start with one bounded tool, one risk owner and one service dependency map. The catalogue describes responsibilities that must be covered; it does not mandate installing every product immediately or maintaining duplicate inventories.

Limitations, remaining risks and conclusion

Material technical limitations

The HTTP service is a loopback laboratory using a basic Python server; it is not a hardened public API. SQLite serializes the small local workload and is not a multi-region exposure service. Authentication failures, schema rejects and some approval-operation rejects do not yet enter the business audit chain; production ingress security telemetry must capture them without exposing credentials. Event hashes reduce raw content but do not anonymize it.

Policy version is a logical identifier, not a cryptographically verified policy-bundle digest. A malicious policy operator could substitute semantics under the same version unless deployment integrity and separation of duties are added. Local administrators can modify authoritative tables and audit state. The outbox has no production backpressure, poison-message handling or authenticated native-product bridge.

Material governance limitations

No named accountable humans, real risk acceptance decisions, DPIA, independent validation, customer challenge process, lawful-basis determination or representative credit dataset is supplied. The populated risk register is an example working artifact whose open fields deliberately prevent a production-ready conclusion. Product choice does not satisfy an obligation until the configured control and operating process are assessed.

Next research experiments

Use a representative, authorized dataset and a fixed model/version to compare task correctness with and without mandatory action controls. Measure prevented unsafe effects, false denials, reviewer burden, end-to-end latency and recovery. Repeat against native product integrations, a malicious tool/RAG corpus, credential theft, policy drift, source outages and response-loss faults. Independent testers should define additional attacks and challenge any accepted residual exposure.

Conclusion

The architecture turns governance requirements into a connected authority and evidence system. CISO Assistant holds the risk record; Microsoft AGT can intercept agent actions; OPA applies current business policy; trusted sources supply facts; approvals bind to exact actions; and adapters must enforce the only permitted write route. The local tests demonstrate selected mechanics of this design. Enterprise governance remains incomplete until the native integrations, independent validation, human accountability and operational recovery paths are deployed and evidenced.

Primary sources 1-9

Accessed 2 November 2026. Source assertions are separated from our architecture choices and observed experiments. Public guidance does not substitute for a current legal applicability assessment.

[1] Erdos Effect

Implementing Governance for Agentic Workflows; 1 Nov 2026

https://www.linkedin.com/pulse/implementing-governance-agentic-workflows-erdos-effect-vipie

[2] NIST

AI RMF Core; GOVERN, MAP, MEASURE, MANAGE

https://airc.nist.gov/airmf-resources/airmf/5-sec-core/

[3] NIST

AI 600-1, Generative Artificial Intelligence Profile; Jul 2024

https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence

[4] NIST

SP 800-53 Rev.5; publication page notes Release 5.2.0 updates

https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

[5] OWASP

Top 10 for Agentic Applications 2026

https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/

[6] FCA

Operational resilience; scope and expectations

https://www.fca.org.uk/firms/operational-resilience

[7] Microsoft

Agent Governance Toolkit repository and release documentation

https://github.com/microsoft/agent-governance-toolkit

[8] Keycloak

Securing applications and services with OpenID Connect

https://www.keycloak.org/securing-apps/oidc-layers

[9] OpenFGA

Authorization concepts

https://openfga.dev/docs/authorization-concepts

Primary sources 10-18

Accessed 2 November 2026. Source assertions are separated from our architecture choices and observed experiments. Public guidance does not substitute for a current legal applicability assessment.

[10] OpenBao

Secrets engines

https://openbao.org/docs/secrets/

[11] intuitem

CISO Assistant Community; functionality and license boundaries

https://github.com/intuitem/ciso-assistant-community

[12] OpenMetadata

Lineage API

https://docs.open-metadata.org/v1.12.x/api-reference/lineage/index

[13] MLflow

Official documentation; registry and evaluation capabilities

https://mlflow.org/docs/latest/

[14] Temporal

Workflow execution overview

https://docs.temporal.io/workflow-execution

[15] OpenTelemetry

Handling sensitive data

https://opentelemetry.io/docs/security/handling-sensitive-data/

[16] DFIR-IRIS

IRIS repository; versioning, deployment and licensing

https://github.com/dfir-iris/iris-web

[17] TheHive Project

Archived repository; current commercial distribution notice

https://github.com/TheHive-Project/TheHive

[18] Bank of England / PRA

SS1/23 Model risk management principles for banks; current publication

https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss

Primary sources 19-27

Accessed 2 November 2026. Source assertions are separated from our architecture choices and observed experiments. Public guidance does not substitute for a current legal applicability assessment.

[19] ICO

DUAA summary of changes; automated decision-making

https://ico.org.uk/about-the-ico/what-we-do/legislation-we-cover/data-use-and-access-act-2025/the-data-use-and-access-act-2025-duaa-summary-of-the-changes/data-protection/

[20] UK legislation

Data (Use and Access) Act 2025, section 80; enacted text

https://www.legislation.gov.uk/ukpga/2025/18/section/80/enacted

[21] ICO

Automated decision-making guidance consultation; review status

https://citizen-space.ico.org.uk/regulatory-risk/adm-guidance-consultation/

[22] ISO

ISO/IEC 42001:2023 public standard overview

https://www.iso.org/standard/42001

[23] BIS / Basel Committee

Risk data aggregation and risk reporting; supervisory framework

https://www.bis.org/committees/bcbs/basel-framework/standard/srp/36/inforce/2019-12-15/published/2019-12-15

[24] Open Policy Agent

REST API reference

https://www.openpolicyagent.org/docs/rest-api

[25] Fairlearn

Fairness assessment and mitigation; official overview

https://fairlearn.org/

[26] Prometheus

Monitoring and alerting overview

https://prometheus.io/docs/introduction/overview/

[27] OWASP

Agent Control Standard resource

https://genai.owasp.org/resource/agent-control-standard-acs/

Component role catalogue 1-6

Keycloak / Identity

JWT signature, issuer, audience, expiry; user and workload identity.

Evidence status: RS256 lab tokens tested; Keycloak connector required. **License baseline:** Apache-2.0. Verify the exact release and optional dependencies.

Microsoft Agent Governance Toolkit / Agent runtime

Intercept tool proposals; sandbox and runtime evidence; central deny wins.

Evidence status: Optional SDK experiment; see results/agt.json. **License baseline:** MIT. Verify the exact release and optional dependencies.

Open Policy Agent / Business policy

Deterministic action, tenant, freshness, budget and approval decisions.

Evidence status: Real HTTP engine tested. **License baseline:** Apache-2.0. Verify the exact release and optional dependencies.

OpenFGA / Relationship permissions

Delegator, agent, customer and record relationships.

Evidence status: Model provided; not deployed. **License baseline:** Apache-2.0. Verify the exact release and optional dependencies.

Temporal / Durable workflow

Durable waits, bounded retries, authenticated approval signals, recovery.

Evidence status: Production design; local approval state tested instead. **License baseline:** MIT server. Verify the exact release and optional dependencies.

CISO Assistant Community / Risk register

Risk ownership, assessment, treatment, exception and acceptance record.

Evidence status: Portable risk register provided; native API integration required. **License baseline:** AGPL-3.0. Verify the exact release and optional dependencies.

Component role catalogue 7-12

OpenMetadata / Metadata

Source ownership, classification, quality, lineage and freshness.

Evidence status: Synthetic source table tested; native connector required. **License baseline:** Apache-2.0. Verify the exact release and optional dependencies.

MLflow / Model register

Model, prompt and evaluation version; validation evidence.

Evidence status: Synthetic workflow validation gate tested; MLflow connector required. **License baseline:** Apache-2.0. Verify the exact release and optional dependencies.

OpenBao / Secrets

Short-lived adapter credentials, revocation, PKI and key protection.

Evidence status: Production integration required. **License baseline:** MPL-2.0. Verify the exact release and optional dependencies.

OpenTelemetry Collector / Telemetry

Redacted correlated spans; export to approved observability systems.

Evidence status: Local minimized audit tested; collector config supplied, untested. **License baseline:** Apache-2.0. Verify the exact release and optional dependencies.

Prometheus + Alertmanager / Metrics and alerting

Policy failures, source age, denial changes and outbox backlog.

Evidence status: Production integration required. **License baseline:** Apache-2.0. Verify the exact release and optional dependencies.

DFIR-IRIS 2.x / Incident management

Triage, evidence, containment and recovery case.

Evidence status: Generic incident outbox tested; native IRIS integration required. **License baseline:** LGPL-3.0. Verify the exact release and optional dependencies.

Component role catalogue 13-18

GLPI / Business inventory and changes

Service owner, criticality, dependency and change tickets.

Evidence status: Production integration required. **License baseline:** GPL-3.0. Verify the exact release and optional dependencies.

PostgreSQL / Evidence graph

Versioned requirement-control-test-event-risk relationships.

Evidence status: Local SQLite evidence chain and relational links tested. **License baseline:** PostgreSQL License. Verify the exact release and optional dependencies.

Fairlearn / Fairness evaluation

Group performance and disparity evaluation with authorized data.

Evidence status: Required validation design; no fairness experiment performed. **License baseline:** MIT. Verify the exact release and optional dependencies.

Kubernetes + Cilium / Workload isolation

Default-deny network access, target-only adapter egress, identities.

Evidence status: Production design; not deployed. **License baseline:** Apache-2.0. Verify the exact release and optional dependencies.

Syft + Grype + Cosign / Supply chain

SBOM, vulnerability gate, signed images and policy bundles.

Evidence status: Release acceptance requirement; not executed. **License baseline:** Apache-2.0. Verify the exact release and optional dependencies.

Ollama + Qwen2.5 0.5B / Local generative model

Optional proposal generation, without execution credentials.

Evidence status: Client supplied; model not downloaded or benchmarked. **License baseline:** MIT runtime; Apache-2.0 selected model. Verify the exact release and optional dependencies.

Native integration package: edition 0.2

The original experiment in this paper remains a historical observation of the enforcement core. The repository has now been extended with native product adapters, deployment and commissioning code, operation-based acceptance and a professional documentation site. This does not turn the original 51 passing checks into evidence of a running 18-component deployment.

Implemented extension

The new package includes Keycloak JWT validation, OpenFGA relationship checks, CISO Assistant risk/control/evidence operations, OpenMetadata ownership/classification/lineage checks, MLflow candidate and release operations, separate OpenBao secret paths, IRIS alerts and GLPI service/ticket operations. PostgreSQL storage, Temporal approval workflows, native model inference, OTLP spans, metrics, alert delivery and per-sink outbox receipts are wired into the gateway and worker code.

Deployment uses a native service Compose package plus resolved official vendor distributions for the more complex products. A dedicated kind/Cilium script performs a before/after isolation test. The release script uses Syft, Grype and Cosign for an image SBOM, vulnerability gate and offline signature verification. These scripts require a capable host and have not all run here.

Additional observations

Twenty-six native adapter contract assertions passed with explicitly simulated HTTP and signed test JWTs. They are not counted as live product integration. Separately, a real temporary MLflow HTTP server accepted and returned the Fairlearn fixture evaluation and registered candidate; the unapproved candidate remained unable to validate. Fixture metrics were 1.0 accuracy and 0.0 selection-rate difference across eight synthetic records. These values measure the fixture plumbing, not fair lending or model quality.

Host limitation

The available execution environment has no Docker daemon, Kubernetes tools, container-management capabilities or eBPF privileges. The complete native acceptance result is therefore BLOCKED, with zero of 18 complete-stack operations asserted as passed. This is recorded in results/all-18-live.json. Native setup also requires deliberately provisioned product credentials and owner/assessment identifiers; none are invented or published.

Documentation and usability

The repository now has a branded landing page, reading paths, component references, quickstart, commissioning guide, generated API documentation, operations runbook, architecture decisions, security policy, contribution guidance and pinned-action validation workflow. The searchable local documentation builds with MkDocs Material. Documentation quality is kept distinct from runtime assurance.

Native component acceptance 1-9

Component	Native responsibility	Required acceptance operation
1. Keycloak	Verified service-account JWT identity	Obtain three native tokens; verify signature, issuer, audience and mapped principal.
2. Microsoft Agent Governance Toolkit	Deterministic agent-side tool interception	Allow one probe; deny an unlisted tool without invoking the function.
3. Open Policy Agent	Business action/context policy	Check valid allow and kill-switch deny against the real policy service.
4. OpenFGA	Record relationship authorization	Allow assigned case and deny a cross-case relationship.
5. Temporal	Durable workflow, bounded retries and approval waits	Execute a native workflow through the protected gateway and inspect its result.
6. CISO Assistant Community	Risk register and evidence records	Create/read back 12 stable risk references; never auto-accept or overwrite owner ratings.
7. OpenMetadata	Data ownership, classification and lineage	Read required owner/classification and verify a downstream lineage edge.
8. MLflow	Versioned evaluation, candidate and approved release	Publish candidate; authorize lab reviewer promotion; verify approved alias and expiry.
9. OpenBao	Separated runtime secret access	Read gateway secrets and prove worker secret path inaccessible to the gateway token.

Implementation and acceptance code are supplied. The table specifies what must run; it does not claim that an unavailable service was exercised. The full component reference links each row to source, deployment and evidence status.

Native component acceptance 10-18

Component	Native responsibility	Required acceptance operation
10. OpenTelemetry Collector	Minimized exported execution spans	Observe a real exported governed-action span and check bearer tokens are absent.
11. Prometheus and Alertmanager	Metrics, rule evaluation and authenticated alert delivery	Read scraped decisions and deliver a synthetic alert into the acknowledged audit path.
12. DFIR-IRIS	Native incident alert records	Create an alert in the configured lab customer and inspect native success response.
13. GLPI	Service inventory and remediation tickets	Read a dedicated synthetic service and create a remediation ticket.
14. PostgreSQL	Transactional business state, evidence and delivery receipts	Read committed target actions, verify audit chain and inspect per-sink receipts.
15. Fairlearn	Actual fairness metric computation	Compute group metrics from a synthetic fixture and publish evaluation to MLflow.
16. Kubernetes and Cilium	Agent isolation with explicit egress	Show a reachable target becomes blocked after policy while gateway remains reachable.
17. Syft, Grype and Cosign	Image inventory, vulnerability gate and offline signing	Generate an image SBOM, reject high/critical findings and verify its local signature.
18. Ollama and Qwen2.5	Local proposal generation without execution credentials	Run the actual model and parse a generated JSON response.

Implementation and acceptance code are supplied. The table specifies what must run; it does not claim that an unavailable service was exercised. The full component reference links each row to source, deployment and evidence status.

Commissioning, evidence and release limits

Complete acceptance criterion

All 18 component groups must pass their native operations on the commissioned dedicated host. A service health response or a mocked contract test is insufficient. The workflow test waits on an exact-action reviewer approval before commitment. Cilium must block a target that was reachable before its policy while preserving the gateway route. Supply-chain tools must scan and verify the built image artifacts, rather than merely report installed versions.

Authority and credential provisioning

A qualified operator provisions a dedicated CISO Assistant folder and assessment, metadata owner and token, IRIS customer/key and GLPI tokens. Bootstrap refuses missing identifiers. OpenBao issues separate gateway, workflow-worker and dispatcher read policies; a gateway credential must not read the worker secret path. Risk sync attaches controls and evidence without automatically changing ratings or acceptance.

Demonstration settings

The supplied deployment uses Keycloak development mode, a persisted Temporal development server, private lab HTTP bindings and a single-share Bao unseal procedure. These enable an inspectable synthetic demonstration, not regulated production operation. Production needs approved TLS, authentication, high availability, key custody and renewal, scoped database/product roles, current vulnerability qualification, backups and restoration evidence.

Operational constraints

The native gateway restricts writes when the pending evidence queue reaches its configured limit. Downstream delivery has per-sink receipts and retains failed events. Concurrent dispatcher workers, remote lost-response races and privileged audit rewriting still require production reconciliation and external evidence protection. A global PostgreSQL guard serializes the laboratory action budget; it is not a demonstrated high-throughput exposure service.

Reproducible entry points

Use scripts/full_stack.py preflight before deployment, configure_full.py for private lab configuration, full_stack.py for explicit deployment phases, commission_native.py for native setup, install_agent_sandbox.py and supply_chain.py for isolation/release checks, and accept_all_components.py for the complete live result. The full guide and component catalogue give the required inputs and interfaces.

Research interpretation

The implementation now covers every named component group at source/deployment level. Successful full-stack operation remains a hypothesis to test on an appropriate host. Neither the expanded documentation nor the extra isolated evaluation experiment removes the independent validation, legal, human accountability, distributed consistency and operational resilience requirements identified in the original paper.